ADR-05 — Retenção e imutabilidade dos logs

Architecture Decision Record · Projeto Steely · Escola de TI · UniCesumar

Status	☒ Proposto ☐ Aceito ☐ Rejeitado ☐ Substituído pelo ADR-___	**Data**	01/11/2026
Responsável	Augusto Palma Guglielmi	**Sprint**	Entrega até 23/11 (Sprints 15 a 17)
Participantes	Augusto Palma Guglielmi, Fabrício Notoya Thomas, Pietro Pasqual Silva, Rafael Tudela Rizental, Thiago Lopes Martins		
Vínculos	RNF-11 · RF-22, RF-02 e RF-20 · STY056 (RN01) · PRM-62, PRM-63 e PRM-64 · Marco Civil art. 15 · LGPD · R-01 · ADR-08, ADR-09, ADR-13, ADR-16 e ADR-21		

1. Contexto

O RNF-11 exige trilha de auditoria imutável, em JSON estruturado, com carimbo UTC e Correlation ID, e verificação de imutabilidade e de mascaramento de dados pessoais. A STY056 limita a consulta ao prazo de retenção e ao nível de permissão. Os parâmetros definem 6 meses para logs de acesso (PRM-62, em linha com o Marco Civil, art. 15) e 5 anos para registros fiscais (PRM-63).

Já definido pelo grupo: o ADR-08 criou o schema `audit` com duas tabelas particionadas por mês e append-only: `audit.system_and_access_logs` (12 meses) e `audit.financial_and_dispute_logs` (60 meses). O ADR-16 cria a partição do mês seguinte e descarta as vencidas. O ADR-13 define o cabeçalho `X-Correlation-Id` em toda requisição e resposta. Falta formalizar o formato, a retenção e, principalmente, **como impedir a alteração**.

Restrições: plano gratuito (o Render Free guarda poucos logs e o Supabase tem 500 MB); nenhum dado pessoal em claro no log (R-01); demonstração da imutabilidade na defesa.

2. Direcionadores da decisão

- **Imutabilidade comprovável:** poder demonstrar que a adulteração é impedida e detectada.
- **Conformidade:** prazos legais (6 meses e 5 anos) e mascaramento de dados pessoais.
- **Custo zero e nenhum serviço novo.**
- **Consulta com permissão (STY056):** filtrar por período e por sensibilidade.
- **Esforço até 23/11:** usar o schema e a rotina de partições já definidos.
- **Desempenho:** o log não pode atrasar as operações críticas.

3. Opções consideradas

Opção A — Tabelas append-only no PostgreSQL com hash encadeado

Descrição: os dois logs do schema `audit`, com permissões que impedem UPDATE e DELETE e um hash em cadeia para detectar adulteração.

Prós:

- Mesmo banco e mesma transação do evento
- Sem custo
- Adulteração detectável
- Já previsto no ADR-08

Contras:

- Quem controla o banco ainda poderia alterar (mitigado por verificação e backup)
- Hash encadeado serializa as inserções
- Consumo do limite de 500 MB

Opção B — Serviço externo de logs

Descrição: enviar os logs a um serviço gerenciado (por exemplo, um plano gratuito de log).

Prós:

- Fora do banco, difícil de alterar
- Busca e retenção prontas

Contras:

- Retenção gratuita curta, inferior aos 12 meses e 5 anos
- Dados fora do controle do grupo (LGPD)
- Dependência externa

Opção C — Arquivos imutáveis em armazenamento de objetos

Descrição: gravar arquivos em armazenamento com bloqueio de escrita (WORM).

Prós:

- Imutabilidade forte

Contras:

- Recurso de bloqueio costuma exigir cartão de crédito
- Mais um serviço
- Consulta por STY056 mais difícil

4. Decisão

Opção escolhida: A — Tabelas append-only no PostgreSQL, em duas partições mensais, com hash encadeado e verificação periódica.

Justificativa: atende à imutabilidade sem custo e sem serviço novo, mantém o evento e o log na mesma transação e aproveita o que os ADRs 08, 13 e 16 já definem. A Opção B não cobre a retenção exigida no plano gratuito, e a Opção C exige serviço pago ou cartão.

Formato (JSON estruturado): `ts_utc`, `correlation_id`, `actor_id` (identificador, nunca nome nem e-mail), `actor_role`, `event_type`, `resource` e `resource_id`, `outcome`, `ip_hash` (IP vindo do Cloudflare, ADR-09), `payload` mascarado, `prev_hash` e `row_hash`.

Duas tabelas e prazos (como no ADR-08):

Tabela	Eventos	Retenção
`audit.system_and_access_logs`	Login, 2FA, captcha e bloqueio, mudança de permissão, ações administrativas, execução de jobs, modo demonstração	12 meses
`audit.financial_and_dispute_logs`	Escrow, ledger de moedas, arremate, devolução, reclamação, decisão da arbitragem e estorno, eliminação de conta	60 meses (5 anos)

Retenção confirmada pelo grupo: 12 meses para logs de sistema e acesso (maior que o mínimo legal de 6 meses; o PRM-62 foi ajustado) e 5 anos para os financeiros (PRM-63). A serialização das inserções pelo hash encadeado foi aceita para o volume da demonstração.

Como impedir a alteração (três camadas):

- **Permissão:** `REVOKE UPDATE, DELETE, TRUNCATE` de todos os papéis da aplicação. A inserção só ocorre pela função `private.audit_log()`, que é `SECURITY DEFINER` (ADR-09).
- **Gatilho:** `BEFORE UPDATE OR DELETE` que sempre lança erro. O único descarte permitido é o do `DROP` da partição vencida, feito pelo job do ADR-16.
- **Hash encadeado:** `row_hash = SHA-256(prev_hash || conteúdo da linha)`, por tabela e por partição mensal. A função `private.audit_verify(inicio, fim)` recalcula a cadeia e aponta a primeira linha adulterada. A verificação roda diariamente pelo job do ADR-16 (`private.audit_verify`) e antes da demonstração.

Mascaramento: o log usa lista permitida de campos. CPF, e-mail, telefone, endereço, conteúdo de chat e imagens nunca entram; só identificadores. O Correlation ID liga log, resposta de erro (RFC 9457) e execução de job (ADR-13 e ADR-16).

Consulta (STY056): pelo painel do perfil de auditoria, restrita ao prazo de retenção e ao nível de permissão; logs financeiros e de disputa exigem permissão mais alta. Exportação síncrona até 10.000 linhas (PRM-64). Todo acesso ao log também é registrado.

Cópia da aplicação: o FastAPI também escreve o mesmo JSON na saída padrão do Render, apenas para depuração. A fonte oficial é sempre o schema `audit`.

5. Consequências

Positivas:

- Imutabilidade e detecção de adulteração demonstráveis ao vivo.
- Prazos de 12 meses e 5 anos aplicados por descarte de partição, sem DELETE.
- Rastreio de ponta a ponta pelo Correlation ID.

Negativas ou riscos aceitos:

- Quem tem acesso total ao banco poderia refazer a cadeia; a mitigação é guardar o hash do último dia na verificação e nos backups de 6 h (ADR-08).
- O hash encadeado serializa as inserções, o que é aceito neste volume.
- Os logs consomem parte do limite de 500 MB do plano gratuito.
- O log de aplicação do Render não é fonte oficial e tem retenção curta.

O que muda:

- **Banco:** função `audit_log`, gatilhos, função de verificação, e permissões de `audit`.
- **Código:** middleware que injeta o Correlation ID e chama o log, com mascaramento por lista permitida.
- **Fluxos:** ADR-03, 06 e 07 gravam seus eventos na tabela financeira ou de sistema, conforme a tabela acima.

6. Validação

#	Cenário de teste	Resultado esperado
1	Tentar `UPDATE` e `DELETE` em uma linha do log por qualquer papel	Operação negada e tentativa registrada
2	Alterar uma linha como superusuário e rodar `audit_verify`	Linha adulterada apontada pela cadeia de hash
3	Amostra de 100 linhas	Nenhum CPF, e-mail, endereço ou texto de chat
4	Uma requisição com `X-Correlation-Id`	Mesmo ID no log, na resposta e na execução do job
5	Partição de 12 e 60 meses vencida	Descartada pelo job; as demais intactas
6	Consulta fora do prazo ou do nível de permissão	Negada (STY056-RN01)

7. Plano de implementação

#	Tarefa	Responsável (proposta)	Sprint (proposta)
1	Tabelas, partições e permissões do schema `audit`	Fabrício	15
2	`audit_log`, gatilhos, hash encadeado e `audit_verify`	Augusto	16
3	Middleware de Correlation ID e mascaramento no FastAPI	Thiago	16
4	Job de partições e verificação diária (ADR-16)	Thiago	16
5	Painel de consulta e exportação de logs (STY056)	Pietro	17
6	Propagar o Correlation ID nas chamadas do app	Rafael	16

Responsáveis e sprints seguem o alinhamento final do grupo de 01/11/2026, com entrega até 23/11.

8. Referências

- RNF-11, RF-22 e STY056; PRM-62, PRM-63 e PRM-64.
- ADR-08 (schema audit e partições), ADR-09 (SECURITY DEFINER), ADR-13 (Correlation ID e RFC 9457), ADR-16 (partições e descarte), ADR-21 (eventos de login).
- Marco Civil da Internet, art. 15; LGPD, art. 46. Documentação do PostgreSQL: particionamento e permissões.

Histórico de revisões

Versão	Data	Autor	Alteração
1.0	01/11/2026	Augusto Palma Guglielmi	Versão inicial, em status Proposto
1.1	01/11/2026	Augusto Palma Guglielmi	Alinhamento final do grupo: retenção de 12 meses confirmada, verificação diária no ADR-16 e hash encadeado aceito